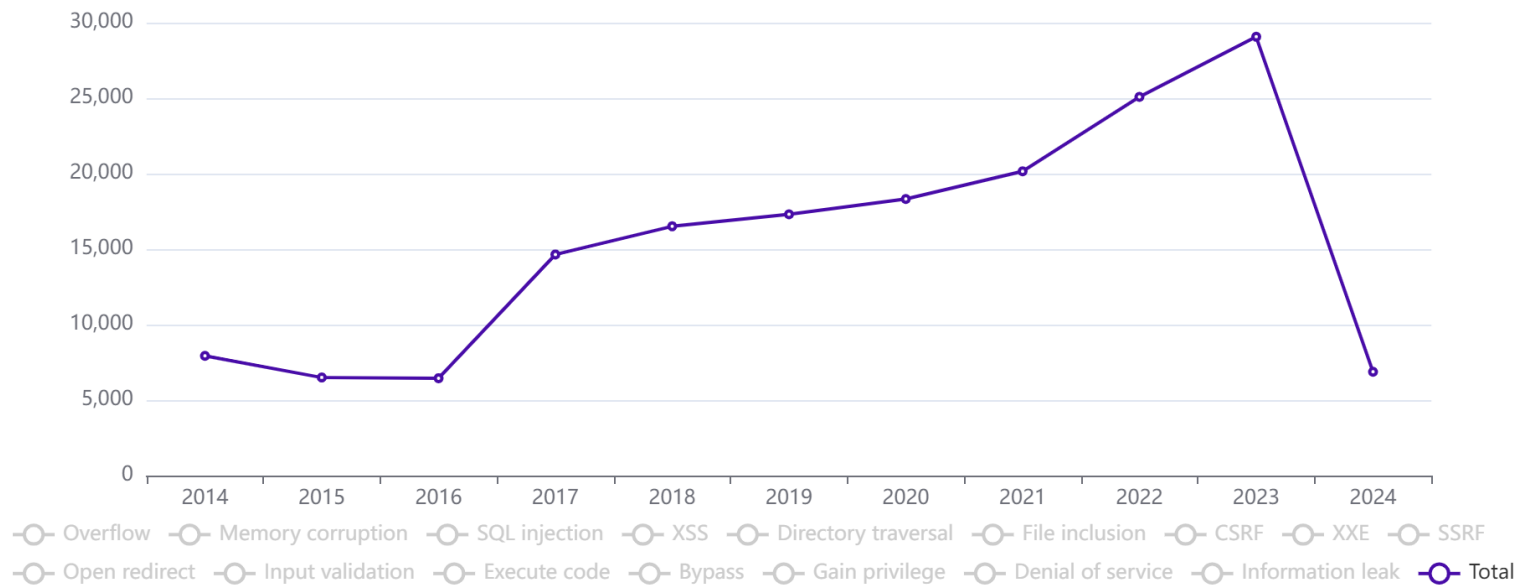


Занятие 6. Организационные аспекты управления уязвимостями

Александр Дорофеев | Генеральный директор «Эшелон Технологии»

Количество уязвимостей

Vulnerabilities by type & year



В среднем публикуется более

70

уязвимостей в день

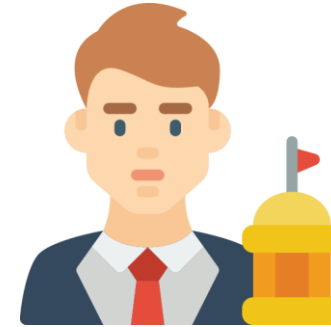
Борьба с уязвимостями



- Разработчик:
 - Процессы разработки безопасного ПО (безопасная разработка)



- Пользователь:
 - Процессы управления уязвимостями



- Регуляторы:
 - Требования к разработчикам СЗИ
 - Методические документы по управлению уязвимостями
 - Ведение базы данных угроз
 - Информирование об уязвимостях

Актуальность

ИСПДН

VIII. Контроль (анализ) защищенности персональных данных (АНЗ)					
АНЗ.1	Выявление, анализ уязвимостей информационной системы и оперативное устранение вновь выявленных уязвимостей		+	+	+
АНЗ.2	Контроль установки обновлений программного обеспечения, включая обновление программного обеспечения средств защиты информации	+	+	+	+
АНЗ.3	Контроль работоспособности, параметров настройки и правильности функционирования программного обеспечения и средств защиты информации		+	+	+
АНЗ.4	Контроль состава технических средств, программного обеспечения и средств защиты информации		+	+	+
АНЗ.5	Контроль правил генерации и смены паролей пользователей, заведения и удаления учетных записей пользователей, реализации правил разграничения доступа, полномочий пользователей в информационной системе			+	+

ГИС

VIII. Контроль (анализ) защищенности информации (АНЗ)					
АНЗ.1	Выявление, анализ уязвимостей информационной системы и оперативное устранение вновь выявленных уязвимостей	+	+	+	
АНЗ.2	Контроль установки обновлений программного обеспечения, включая обновление программного обеспечения средств защиты информации	+	+	+	
АНЗ.3	Контроль работоспособности, параметров настройки и правильности функционирования программного обеспечения и средств защиты информации	+	+	+	
АНЗ.4	Контроль состава технических средств, программного обеспечения и средств защиты информации	+	+	+	
АНЗ.5	Контроль правил генерации и смены паролей пользователей, заведения и удаления учетных записей пользователей, реализации правил разграничения доступа, полномочий пользователей в информационной системе	+	+	+	

КИИ

XIV. Управление обновлениями программного обеспечения (ОПО)					
ОПО.0	Регламентация правил и процедур управления обновлениями программного обеспечения	+	+	+	
ОПО.1	Поиск, получение обновлений программного обеспечения от доверенного источника	+	+	+	
ОПО.2	Контроль целостности обновлений программного обеспечения	+	+	+	
ОПО.3	Тестирование обновлений программного обеспечения	+	+	+	
ОПО.4	Установка обновлений программного обеспечения	+	+	+	

28. В рамках функционирования системы безопасности субъектом критической информационной инфраструктуры должны быть внедрены следующие процессы:

- планирование и разработка мероприятий по обеспечению безопасности значимых объектов критической информационной инфраструктуры;
- реализация (внедрение) мероприятий по обеспечению безопасности значимых объектов критической информационной инфраструктуры;
- контроль состояния безопасности значимых объектов критической информационной инфраструктуры;
- совершенствование безопасности значимых объектов критической информационной инфраструктуры.

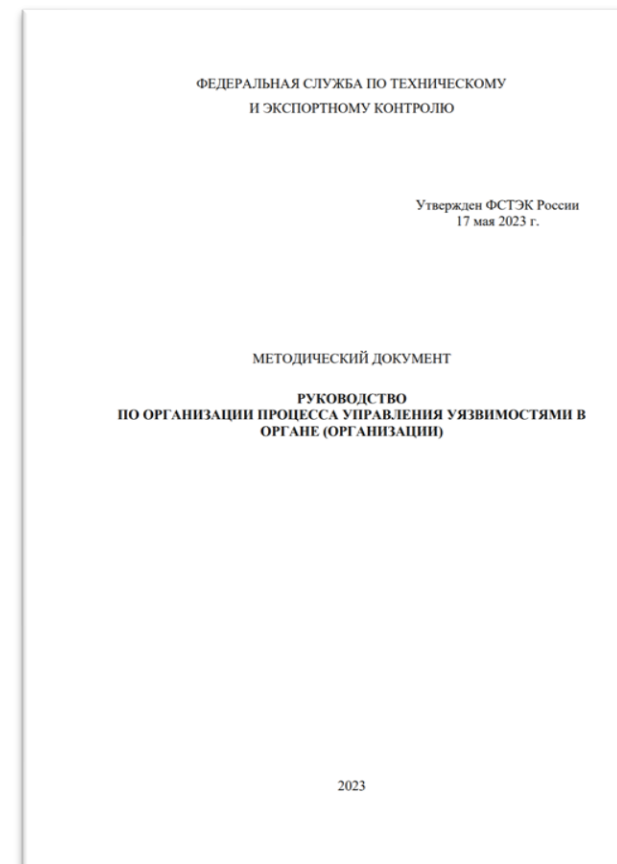
АСУ ТП

V. Аудит безопасности (АУД)				
АУД.0	Разработка политики аудита безопасности	+	+	+
АУД.1	Инвентаризация информационных ресурсов	+	+	+
АУД.2	Анализ уязвимостей и их устранение	+	+	+
АУД.3	Генерирование временных меток и (или) синхронизация системного времени	+	+	+
АУД.4	Регистрация событий безопасности	+	+	+
АУД.5	Контроль и анализ сетевого трафика			+
АУД.6	Защита информации о событиях безопасности	+	+	+
АУД.7	Мониторинг безопасности	+	+	+
АУД.8	Реагирование на сбои при регистрации событий безопасности	+	+	+
АУД.9	Анализ действий пользователей			+
АУД.10	Проведение внутренних аудитов	+	+	+
АУД.11	Проведение внешних аудитов			+

Руководство от ФСТЭК России

МЕТОДИЧЕСКИЙ ДОКУМЕНТ РУКОВОДСТВО ПО ОРГАНИЗАЦИИ ПРОЦЕССА УПРАВЛЕНИЯ УЯЗВИМОСТЯМИ В ОРГАНЕ (ОРГАНИЗАЦИИ)

- Для кого:
 - государственных органов
 - организаций, в том числе субъектов КИИ
- Для чего:
 - создание основы для разработки детальных регламентов и стандартов по управлению уязвимостями с учетом особенностей функционирования органов (организаций) и организация взаимодействия между структурными подразделениями органов (организаций) по вопросам устранения уязвимостей



Цикл управления уязвимостями



Распределение обязанностей

- Специалисты по информационной безопасности:
 - Мониторинг уязвимостей и оценка их применимости
 - Оценка уязвимостей
 - Определение методов и приоритетов устранения уязвимостей
 - Разработка и реализация компенсирующих мер защиты информации
 - Контроль устранения уязвимостей
 - Разработка предложений по улучшению процесса управления уязвимостями
- Системные администраторы:
 - Устранение уязвимостей
 - Разработка и реализация компенсирующих мер защиты информации

1. МОНИТОРИНГ УЯЗВИМОСТЕЙ И ОЦЕНКА ИХ ПРИМЕНИМОСТИ

- Анализ информации об уязвимости
- Оценка применимости уязвимости
- Принятие решений на получение дополнительной информации
- Постановка задачи на сканирование объектов
- Сканирование объектов
- Оценка защищенности

Источники информации об уязвимостях

- БДУ ФСТЭК России: <https://bdu.fstec.ru/>
- NIST NVD: <https://nvd.nist.gov/>
- Chinese National Vulnerability Database (CNNVD): <https://www.cnvd.org.cn/>
- Debian GNU/Linux Security Bug Tracker <https://security-tracker.debian.org/tracker/>
- Ubuntu CVE Tracker <https://people.canonical.com/~ubuntu-security/cve/>
- RHEL/CentOS Security Data <https://www.redhat.com/security/data/metrics/>

2. ОЦЕНКА УЯЗВИМОСТЕЙ

- Получение информации об объектах, подверженных уязвимости
- Определение уровня опасности уязвимости
- Определение влияния на информационные системы
- Расчет критичности уязвимости

От чего зависит наше восприятие опасности уязвимости?

■ Внешние факторы:

- Оценка уязвимости по CVSS
- Оценка потенциальной возможности эксплуатации (EPSS)
- Наличие опубликованных эксплойтов

■ Внутренние факторы:

- Доступность актива извне
- Особенности ИТ-инфраструктуры
- Особенности конфигурации систем
- Критичность активов с точки зрения бизнеса

Степень опасности уязвимости

- Common Vulnerability Scoring System (CVSS) — это открытый стандарт, используемый для расчета количественной оценки степени опасности.
- При расчете учитываются такие факторы, как наличие эксплойта, возможность удаленной эксплуатации, необходимость авторизации, возможные последствия.
- Калькуляторы для расчета CVSS 2/3/3.1:
<https://bdu.fstec.ru/calc>

Оценка по CVSS v4: CVE-2022-41741

CVSS v4 Score: Base 7.3

Metric	Value	Comments
Attack Vector	Local	У атакующего должен быть интерактивный доступ к системе
Attack Complexity	Low	Специальных условий и знаний не требуется
Attack Requirements	Present	Для успешной эксплуатации этой уязвимости необходимо выполнить множество условий, требующих сбора информации и подготовки цели.
Privileges Required	Low	Атакующий должен иметь возможность поместить файл в корневой каталог NGINX.
User Interaction	None	Взаимодействия с пользователем не требуется
Vulnerable System Confidentiality	High	Злоумышленник может выполнить произвольный код на уязвимой системе с повышенными привилегиями.
Vulnerable System Integrity	High	Злоумышленник может выполнить произвольный код на уязвимой системе с повышенными привилегиями.
Vulnerable System Availability	High	Злоумышленник может выполнить произвольный код на уязвимой системе с повышенными привилегиями.
Subsequent System Confidentiality	None	Это не повлияет на последующую конфиденциальность системы.
Subsequent System Integrity	None	Это не повлияет на последующую целостность системы.
Subsequent System Availability	None	Это не повлияет на последующую доступность системы.

Определение степени опасности уязвимости

- CVSSv2:
 - Низкая (Low) – 0.0 – 3.9
 - Средняя (Medium) – 4.0 – 6.9
 - Высокая (High) – 7.0 – 10.0
- CVSSv3/v3.1/v4:
 - Не определен (None) – 0.0
 - Низкая (Low) – 0.1 – 3.9
 - Средняя (Medium) – 4.0 – 6.9
 - Высокая (High) 7.0 – 8.9
 - Критическая (Critical) – 9.0 – 10.0



CVE

- CVE (Common Vulnerabilities and Exposures) — база данных общеизвестных уязвимостей информационной безопасности. Каждой уязвимости присваивается идентификационный номер вида CVE-год-номер, описание и ряд общедоступных ссылок с описанием.

- <https://www.cve.org/>

← → ↻ cve.mitre.org/cgi-bin/cvename.cgi?name=CVE-2011-2523

CVE-ID	
CVE-2011-2523	Learn more at National Vulnerability Database (NVD) • CVSS Severity Rating • Fix Information • Vulnerable Software Versions • SCAP Mappings • CPE Information
Description	
vsftpd 2.3.4 downloaded between 20110630 and 20110703 contains a backdoor which opens a shell on port 6200/tcp.	
References	
Note: References are provided for the convenience of the reader to help distinguish between vulnerabilities. The list is not intended to be complete.	
• MISC:http://packetstormsecurity.com/files/162145/vsftpd-2.3.4-Backdoor-Command-Execution.html • MISC:https://access.redhat.com/security/cve/cve-2011-2523 • MISC:https://packetstormsecurity.com/files/102745/Vsftpd-2.3.4-Backdoor-Command-Execution.html • MISC:https://security-tracker.debian.org/tracker/CVE-2011-2523 • MISC:https://vigilance.fr/vulnerability/vsftpd-backdoor-in-version-2-3-4-10805 • MLIST:[oss-security] 20110711 Re: vsftpd download backdoored • URL:https://www.openwall.com/lists/oss-security/2011/07/11/5	
Assigning CNA	
Red Hat, Inc.	
Date Record Created	
20110615	Disclaimer: The record creation date may reflect when the CVE ID was allocated or reserved, and does not necessarily reflect when the CVE was updated in CVE.
Phase (Legacy)	
Assigned (20110615)	
Votes (Legacy)	
Comments (Legacy)	
Proposed (Legacy)	
N/A	
This is a record on the CVE List , which provides common identifiers for publicly known cybersecurity vulnerabilities.	
SEARCH CVE USING KEYWORDS: Submit	
You can also search by reference using the CVE Reference Maps .	
For More Information: CVE Request Web Form (select "Other" from dropdown)	

Идентификаторы CVE и BDU в Сканер-ВС 6

ЗАДАЧИ

Активы

Задачи

Отчеты

Карты сети

Инструменты

Администрирование

Проект_01

Ru

admin

Главная / Список задач / Поиск уязвимостей / Уязвимое ПО / internet explorer

Уязвимое ПОИстория

Поиск

	CVE	БДУ	CVSS2 балл	CVSS3 балл	Уровень критичности
☐	CVE-2016-3325	BDU:2016-02156	2,6	3,1	Низкий
☐	CVE-2016-3321	BDU:2016-01960	1,9	2,5	Низкий
☐	CVE-2016-7199	BDU:2016-02406	2,6	3,1	Низкий
☐	CVE-2016-7227	BDU:2016-02363	2,6	3,1	Низкий
☐	CVE-2016-3274	BDU:2016-01880	2,6	3,1	Низкий
☐	CVE-2016-3276	BDU:2016-01879	2,6	3,1	Низкий
☐	CVE-2016-3291	BDU:2016-02165	2,6	2,4	Низкий
☐	CVE-2016-3351	BDU:2016-02148	2,6	3,1	Низкий
☐	CVE-2018-0942	—	2,1	2,6	Низкий
☐	CVE-2016-7239	BDU:2016-02360	2,6	3,1	Низкий
☐	CVE-2015-0055	—	4,3	—	Средний
☐	CVE-2014-6365	—	4,3	—	Средний
☐	CVE-2014-0268	BDU:2014-00206	4,3	—	Средний
☐	CVE-2015-0054	—	4,3	—	Средний
☐	CVE-2014-6350	—	4,3	—	Средний

Отображать на странице: 25

1-25 из 718 элементов

1 из 29 страниц

Карточка уязвимости в Сканер-ВС 6

★

ЗАДАЧИ

Активы

Задачи

Отчеты

Карты сети

Инструменты

Администрирование

Проект_01

Ru

admin

Главная / Список задач / Поиск уязвимостей / Уязвимое ПО / python3-xdg /

Информация по найденной уязвимости

Высокий

CVE-2019-12761

Информация об уязвимости

Описание

Проблема с внедрением кода была обнаружена в PyXDG до 0.26 с помощью созданного кода Python в элементе Категории XML-документа меню в файле .menu. XDG_CONFIG_DIRS должен быть настроен для запуска синтаксического анализа xdg.Menu.parse в каталоге, содержащем этот файл. Это связано с отсутствием дезинфекции в xdg/Menu.py перед вызовом на оценку.

CVE	CVE-2019-12761
БДУ	BDU:2021-05299
CVSS2 вектор	AV:N/AC:H/Au:N/C:P/I:P/A:P
CVSS2 балл	5.1
CVSS3 вектор	CVSS:3.0/AV:L/AC:L/PR:N/UI:R/S:C/C:L/I:L/A:L
CVSS3 балл	7.5

Информация по уязвимому ПО

Название	python3-xdg
Связанные названия	python3-xdg, pyxdg
Версия	0.25-5

Рекомендации

Конфигурация

Эксплойты

debian

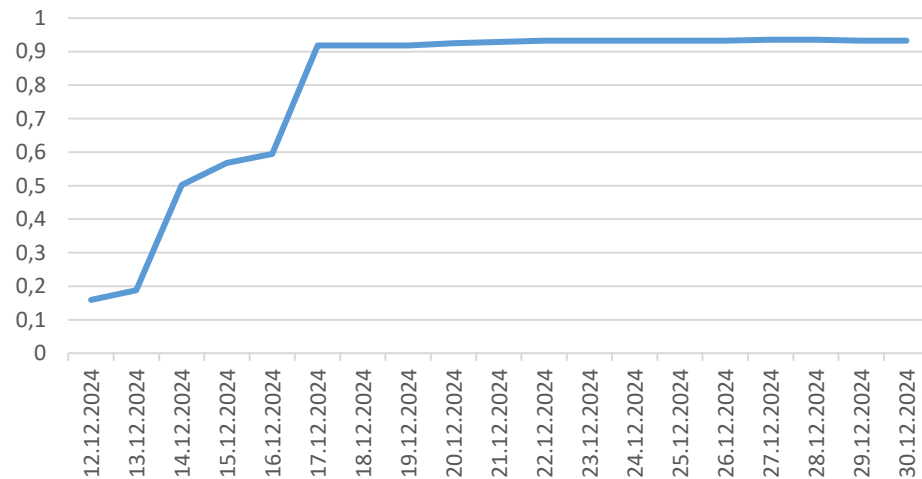
```
1 {
2   "os_name": "debian",
3   "soft_name": "pyxdg",
4   "trait": {
5     "fixed": "0.26-1"
6   }
7 }
```

EPSS

- EPSS предоставляет возможности для эффективного управления уязвимостями на основе данных. Основана на данных и использует текущую информацию об угрозах из CVE и реальные данные об эксплойтах.
- Модель EPSS выдает оценку вероятности от 0 до 1 (от 0 до 100 %), где чем выше оценка, тем больше вероятность того, что уязвимость будет использована.

Уязвимость Log4shell

EPSS CVE-2021-44228



24.11.21

Chen Zhaojun
Обнаруживает
уязвимость

26.11.21

Резервирование
идентификатора
CVE-2021-44228

06.12.21

Выпуск Log4j
2.15.0,
в которой
закрита
уязвимость

09.12.21

Публикация
в Твиттере

10.12.21

Публикация
информации об
уязвимости
CVE-2021-44228

12.12.21

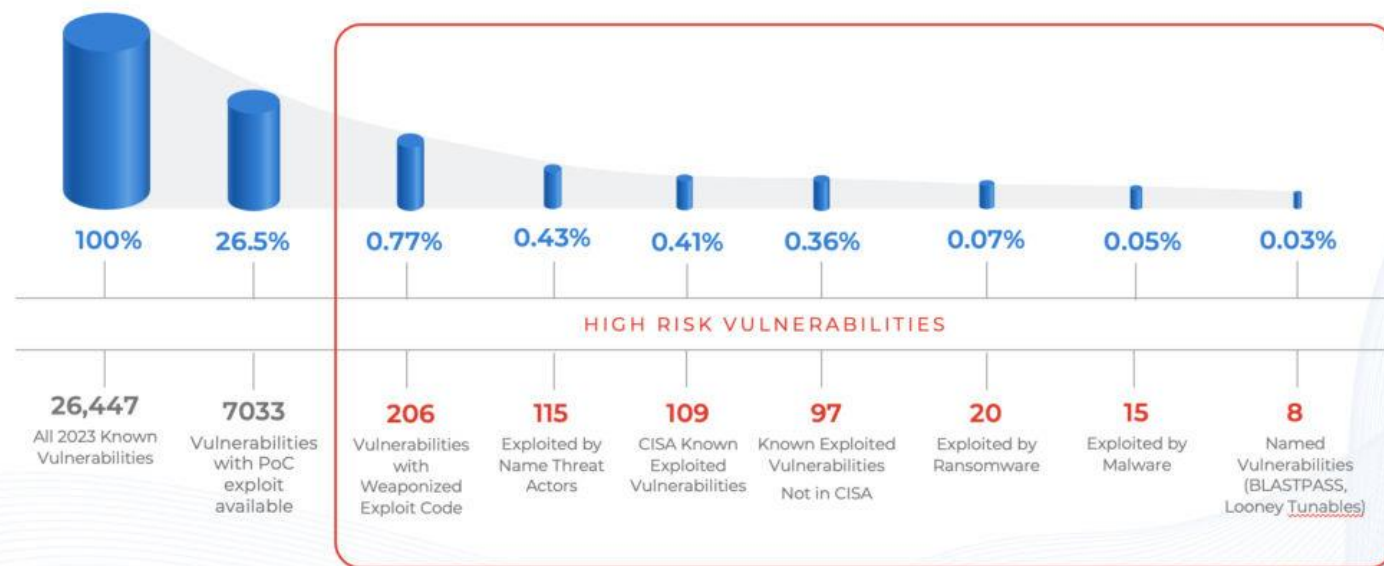
Появилась
оценка EPSS

17.12.21

Повышение уровня опасности
до критического, так как 2.15.0
все уязвимы.

Какой процент реально опасных уязвимостей?

Vulnerability Threat Landscape 2023



Всего уязвимостей

Доказательство возможности эксплуатации

Наличие «боевого» эксплойта

Применение группировками

Наличие в KEV

Эксплуатируемые, но не в KEV

Используемые шифровальщиками

Используемые другими злоумышленниками

Имеющие собственные имена

Источник: <https://blog.qualys.com/vulnerabilities-threat-research/2023/12/19/2023-threat-landscape-year-in-review-part-one>

Known Exploited Vulnerabilities Catalog

The screenshot shows the CISA Known Exploited Vulnerabilities Catalog website. The header includes the CISA logo and the text "AMERICA'S CYBER DEFENSE AGENCY". Below the header is a navigation bar with links for Topics, Spotlight, Resources & Tools, News & Events, Careers, and About. A search bar is located on the right side of the navigation bar. The main content area is divided into two columns. The left column contains a "Filters" section with a search bar, a "Date Added" dropdown, a "Sort by" dropdown, and an "Items per page" dropdown. The right column contains the title "Known Exploited Vulnerabilities Catalog" and a paragraph explaining the purpose of the catalog. Below the paragraph is a link to "HOW TO USE THE KEV CATALOG". The main content area also displays a list of vulnerabilities, with the first entry being "CVE-2024-27198" for "JetBrains TeamCity Authentication Bypass Vulnerability".

Filters

What are you looking for?

Date Added (optional)

Sort by (optional)

Items per page (optional)

APPLY

Vendor/Project +

Known Exploited Vulnerabilities Catalog

For the benefit of the cybersecurity community and network defenders—and to help every organization better manage vulnerabilities and keep pace with threat activity—CISA maintains the authoritative source of vulnerabilities that have been exploited in the wild. Organizations should use the KEV catalog as an input to their vulnerability management prioritization framework.

[HOW TO USE THE KEV CATALOG](#)

The KEV catalog is also available in the following formats:

- [CSV](#)
- [JSON](#)
- [JSON Schema](#)

Showing 1 - 20 of 1089

JETBRAINS | TEAMCITY

CVE-2024-27198

JetBrains TeamCity Authentication Bypass Vulnerability

JetBrains TeamCity contains an authentication bypass vulnerability that allows an attacker to perform admin actions.

- Action:** Apply mitigations per vendor instructions or discontinue use of the product if mitigations are unavailable.
- Known To Be Used in Ransomware Campaigns?:** Unknown
- Date Added:** 2024-03-07
- Due Date:** 2024-03-28

<https://www.cisa.gov/news-events/directives/bod-22-01-reducing-significant-risk-known-exploited-vulnerabilities>

Где публикуются эксплойты?

The screenshot displays the Exploit-DB website interface. At the top, there's a dark blue header with the 'EXPLOIT DATABASE' logo and navigation icons. Below the header, a sidebar on the left contains a vertical menu with icons for home, search, and other features. The main content area shows a list of exploits with columns for Date, D (Download), A (Add), V (Verify), Title, Type, Platform, and Author. The list is filtered to show 15 entries, and a search bar is visible on the right. Below the list, there's a pagination bar with links for 'FIRST', 'PREVIOUS', '1', '2', '3', '4', '5', '3062', 'NEXT', and 'LAST'. At the bottom, a dark blue navigation bar contains four sections: 'Databases' (Exploits, Google Hacking, Papers, Shellcodes), 'Links' (Search Exploit-DB, Submit Entry, SearchSploit Manual, Exploit Statistics), 'Sites' (OffSec, Kali Linux, VulnHub), and 'Solutions' (Courses and Certifications, Learn Subscriptions, OffSec Cyber Range, Proving Grounds, Penetration Testing Services).

Date	D	A	V	Title	Type	Platform	Author
2024-03-16	↓		×	vm2 - sandbox escape	Local	Multiple	Calil Khalil
2024-03-16	↓		×	UPS Network Management Card 4 - Path Traversal	WebApps	PHP	Victor Garcia
2024-03-16	↓		×	Nokia BMC Log Scanner - Remote Code Execution	WebApps	Linux	Carlos Andres Gonzalez, Matthew Gregory
2024-03-16	↓		×	Karaf v4.4.3 Console - RCE	WebApps	Java	Andrzej Olchawa, Milenko Starik
2024-03-16	↓		×	LaborOfficeFree 19.10 - MySQL Root Password Calculator	Local	Windows	Peter Gabaldon
2024-03-16	↓		×	Winter CMS 1.2.3 - Server-Side Template Injection (SSTI) (Authenticated)	WebApps	PHP	tmrswrr
2024-03-14	↓		×	KITTY 0.76.1.13 - Command Injection	Local	Windows	DEFCESCO
2024-03-14	↓		×	KITTY 0.76.1.13 - 'Start Duplicated Session Username' Buffer Overflow	Local	Windows	DEFCESCO
2024-03-14	↓		×	KITTY 0.76.1.13 - 'Start Duplicated Session Hostname' Buffer Overflow	Local	Windows	DEFCESCO
2024-03-14	↓		×	GitLab CE/EE < 16.7.2 - Password Reset	Remote	Java	0xB455
2024-03-14	↓		×	Ruijie Switch PSG-5124 26293 - Remote Code Execution (RCE)	Remote	Hardware	ByteHunter
2024-03-14	↓		×	Viessmann Vitagate 300 2.1.3.0 - Remote Code Execution (RCE)	Remote	Hardware	ByteHunter
2024-03-14	↓		×	SolarView Compact 6.00 - Command Injection	Remote	Hardware	ByteHunter
2024-03-14	↓		×	Honeywell PM43 < P10.19.050004 - Remote Code Execution (RCE)	Remote	Hardware	ByteHunter
2024-03-14	↓		×	JetBrains TeamCity 2023.05.3 - Remote Code Execution (RCE)	Remote	Java	ByteHunter

Showing 1 to 15 of 45,928 entries

Databases	Links	Sites	Solutions
Exploits	Search Exploit-DB	OffSec	Courses and Certifications
Google Hacking	Submit Entry	Kali Linux	Learn Subscriptions
Papers	SearchSploit Manual	VulnHub	OffSec Cyber Range
Shellcodes	Exploit Statistics		Proving Grounds
			Penetration Testing Services

Информация о доступных эксплойтах

★

ЗАДАЧИ

Активы

Задачи

Отчеты

Карты сети

Инструменты

Администрирование

Проект_01

▼

Ru

admin

Главная / Список задач / Поиск уязвимостей / Уязвимое ПО / libqt4-opengl /

Информация по найденной уязвимости

Средний

CVE-2009-3272

Информация об уязвимости

Описание

Уязвимость потребления стека в WebKit.dll в WebKit в Apple Safari 3.2.3 и, возможно, в других версиях до 4.1.2, позволяет удаленным злоумышленникам вызывать отказ в обслуживании (сбой приложения) с помощью кода JavaScript, который вызывает eval в длинной строке, состоящей из последовательностей/.

CVE	CVE-2009-3272
БДУ	—
CVSS2 вектор	AV:N/AC:L/Au:N/C:N/I:N/A:P
CVSS2 балл	5
CVSS3 вектор	—
CVSS3 балл	—

Информация по уязвимому ПО

Название	libqt4-opengl
Связанные названия	libqt4-opengl, qt4-x11
Версия	4:4.8.7+dfsg-20astra3

Рекомендации

Конфигурация

Эксплойты

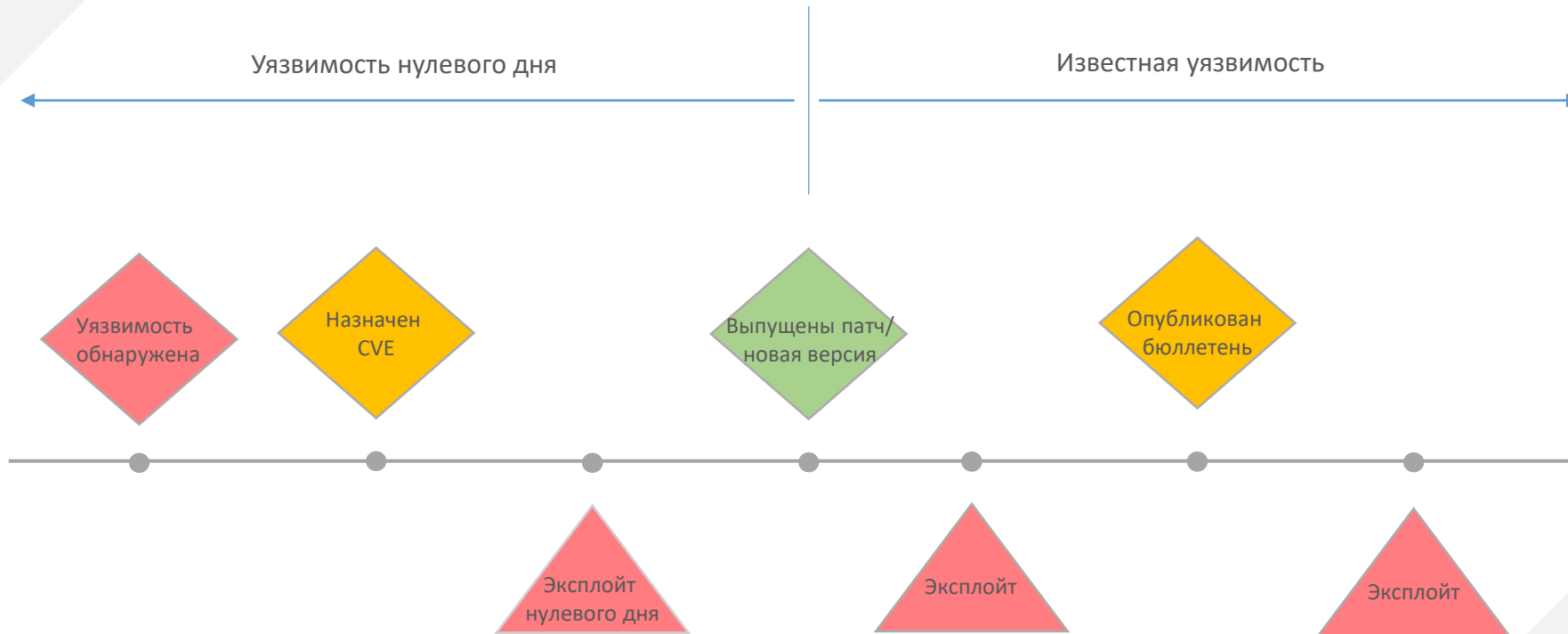
exploitdb

<https://www.exploit-db.com/exploits/9606>

Теги и критичность

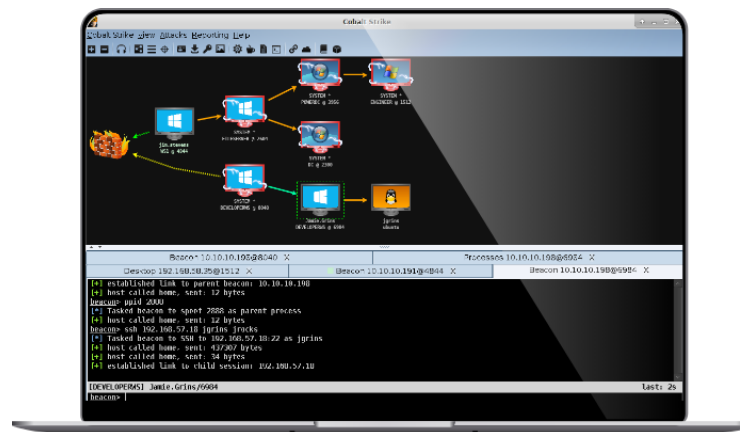
★ АКТИВЫ Активы Задачи Отчеты Карты сети Инструменты Администрирование Проект_01 Ru admin									
Главная / Активы Добавить актив + Поиск									
		Название	IPv4	Тип устройства	Тип ОС	Теги	Создано	Обновлено	
☐	⚠	Windows10	10.0.5.171	рабочая станция	Windows	Производство	19.03.2024, 09:45:11	19.03.2024, 10:18:39	
☐	⚠	Ubuntu 20.04	10.0.5.84	виртуальная машина	Linux	Разработка	19.03.2024, 09:46:44	19.03.2024, 10:53:26	
☐	⚠	Astra Linux 1.7.4	10.0.5.50	сервер	Linux	Бухгалтерия	19.03.2024, 09:46:13	19.03.2024, 10:19:25	
☐	✅	Debian 11	10.0.5.138	другое	Linux	Маркетинг	19.03.2024, 09:47:48	19.03.2024, 10:55:07	
☐	⚠	Windows server 2016	10.0.5.65	сервер	Windows	Продажи	19.03.2024, 09:57:33	19.03.2024, 10:53:58	
Отображать на странице: 25 1-5 из 5 элементов 1 из 1 страниц									

Жизненный цикл уязвимости



Фреймворки для эксплуатации

- Metasploit Framework
- Core Impact
- Cobalt Strike
- Canvas



3. ОПРЕДЕЛЕНИЕ МЕТОДОВ И ПРИОРИТЕТОВ УСТРАНЕНИЯ УЯЗВИМОСТЕЙ

- Определение приоритетности устранения уязвимостей
- Определение методов устранения уязвимостей
- Принятие решения о срочной установке обновлений
- Создание заявки на срочную установку обновления
- Принятие решения о срочной реализации компенсирующих мер защиты информации
- Создание заявки на установку обновления
- Создание заявки на реализацию компенсирующих мер защиты информации

4. УСТРАНЕНИЕ УЯЗВИМОСТЕЙ

- Согласование установки с руководством подразделения ИТ
- Тестирование обновления
- Установка обновления в тестовом сегменте
- Принятие решения об установке обновления
- Установка обновления
- Формирование плана установки обновлений
- Разработка и реализация компенсирующих мер защиты информации

Способы устранения уязвимостей

- Установка патча или новой версии
- Отключение сетевой службы, если есть возможность ее заменить или отказаться вовсе
- Ограничение доступа к уязвимому сервису или активу (например, ограничение по IP)
- Использование средств защиты, блокирующих эксплуатацию уязвимости (IPS, WAF, AV)



Рекомендуемые сроки устранения уязвимостей

- критический уровень опасности до 24 часов
- высокий уровень опасности – до 7 дней
- средний уровень опасности – до 4 недель
- низкий уровень опасности – до 4 месяцев

А что на западе?

- Британский центр кибербезопасности:
 - Вне зависимости от критичности уязвимости:
 - Сервисы, доступные из интернет - 5 дней
 - ОС и приложения - 7 дней
 - Внутренние и автономные сервисы ПО - 14 дней



National Cyber
Security Centre

Источник: <https://www.ncsc.gov.uk/collection/vulnerability-management/guidance/policy-update-by-default>

5. Контроль устранения уязвимостей

- Принятие решения о способе контроля
- Проверка объектов на наличие уязвимостей
- Оценка защищенности
- Выявление отклонений и неисполнений
- Разработка предложений по улучшению процесса управления уязвимостями



Запуск по расписанию и отправка событий в SIEM



ЗАДАЧИ

Активы

Задачи

Отчеты

Карты сети

Инструменты

Администрирование

Проект_01

Ru

admin

[Главная](#) / [Список задач](#) / [Новая задача](#) / Инвентаризация

Инвентаризация

Настройки

Расписание

Запуск задачи по расписанию

☐ 1 раз ☒ По расписанию

Расписание запросов (Cron)

20 2 * 1,2,3 * ☐ Заполнить вручную

Минуты

Часы

Дни

Месяцы

Дни недели

☒ Конкретное значение

20

Сохранить

Выводы

- Процессы управления уязвимостями достаточно хорошо проработаны методически.
- Инструментарий для ключевого процесса по выявлению уязвимостей разработан и доступен.
- Ключевым навыком экспертов является приоритезация уязвимостей.

Тест

Количество вопросов: 18

Проходной балл: 14

Тест доступен: до 24:00 28 апреля

Сертификаты будут разосланы 3-го мая

Ссылка на тест: <https://forms.gle/hwrnxxnMLRJzZwd6T7>

Обратная связь о Сканер-ВС 6

- Анонимно
- Заполнение формы займет 2 минуты.
- Ссылка: <https://forms.gle/tMQRNxBSrAcUF5s2A>

Спасибо!

Сканер-ВС 6 в телеграм

